

Phase 3: Vulnerability Assessment (Testing Phase)

3.1 Assessment Methodology

To identify security weaknesses in the Student Management System, a hybrid assessment approach was utilized:

- **Static Application Security Testing (SAST):** The open-source tool **Bandit (v1.9.4)** performed a recursive scan of the entire Python codebase. This version of the code was intentionally "salted" with various insecure coding patterns to test the efficacy of automated security gates.
- **Manual Code Review:** A line-by-line review was conducted to identify complex **Business Logic Flaws** (such as the role-escalation path) and **Broken Authentication** configurations that may not trigger automated SAST rules.

3.2 Full Scan Results

The automated scan evaluated 683 lines of code and identified **32 total issues**:

- **High Severity:** 7 issues
- **Medium Severity:** 10 issues
- **Low Severity:** 15 issues

The high number of findings confirms that the technical implementation accurately reflects the critical risks defined in the Phase 1 Attack Scenario.

3.3 Vulnerability Register

The following table summarizes the key vulnerabilities found, mapping the automated Bandit Test IDs to the risks established in Phase 1.

Vulnerability	Description & Technical Proof	CVSS Score	Severity
SQL Injection (CWE-89)	Query construction via string concatenation in <code>auth.py</code> . Found by Bandit as B608 .	9.8	Critical

Vulnerability	Description & Technical Proof	CVSS Score	Severity
Insecure File Upload (CWE-434)	Lack of validation allows RCE via shell injection. Found by Bandit as B605/B602 in <code>files.py</code> .	9.8	Critical
Privilege Escalation (CWE-285)	Logic flaw in <code>profile.py</code> allowing unauthorized role updates. Technically supported by B307 (eval usage) .	8.8	High
Sensitive Data Exposure	Leaking plain-text passwords in API responses and using hardcoded secrets (B105/B106).	8.5	High
Path Traversal (CWE-22)	Retrieval endpoint lacks sanitization, allowing access to system configuration files via <code>../</code> sequences.	7.5	High
Insecure Cryptography	Use of weak MD5 hashing (B324) and insecure ciphers (B304/B305) in <code>auth.py</code> and <code>utils.py</code> .	7.5	High
Broken Authentication	Default hardcoded administrative credentials found in <code>admin_login</code> (B107).	7.5	High
Log Injection (CWE-117)	User input is logged directly without sanitization, allowing for the forgery of system audit logs.	5.3	Medium

3.4 Bandit Output

Metrics:

Total lines of code: 683
Total lines skipped (#nosec): 0

hardcoded_password_string: Possible hardcoded password: 'admin123'
Test ID: B105
Severity: LOW
Confidence: MEDIUM
CWE: [CWE-259](#)
File: [./app/routes/auth.py](#)
Line number: 37
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html

```
36         # BANDIT B105: Hardcoded password string
37         admin_password = "admin123"
38
```

assert_used: Use of assert detected. The enclosed code will be removed when compiling to optimised byte code.
Test ID: B101
Severity: LOW
Confidence: HIGH
CWE: [CWE-703](#)
File: [./app/routes/auth.py](#)
Line number: 40
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b101_assert_used.html

```
39         # BANDIT B101: Use of assert for security
40         assert creds.password != "", "Password cannot be empty"
41
```

hardcoded_password_string: Possible hardcoded password: "
Test ID: B105
Severity: LOW
Confidence: MEDIUM
CWE: [CWE-259](#)
File: [./app/routes/auth.py](#)
Line number: 40
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b105_hardcoded_password_string.html

```
39         # BANDIT B101: Use of assert for security
40         assert creds.password != "", "Password cannot be empty"
41
```

hashlib: Use of weak MD5 hash for security. Consider `usedforsecurity=False`
Test ID: B324
Severity: HIGH
Confidence: HIGH
CWE: [CWE-327](#)
File: [./app/routes/auth.py](#)
Line number: 43
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html

```
42         # BANDIT B303: Use of insecure hash function
43         hashed_pass = hashlib.md5(creds.password.encode()).hexdigest()
44
```

blacklist: Standard pseudo-random generators are not suitable for security/cryptographic purposes.
Test ID: B311
Severity: LOW
Confidence: HIGH
CWE: [CWE-330](#)
File: [./app/routes/auth.py](#)
Line number: 46
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random

```
45         # BANDIT B311: Use of random for security token
46         insecure_token = random.random()
47
```

try_except_pass: Try, Except, Pass detected.
Test ID: B110
Severity: LOW
Confidence: HIGH
CWE: [CWE-703](#)
File: [./app/routes/auth.py](#)
Line number: 53
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

```
52         pass
53         except Exception:
54             pass
55
```

hardcoded_sql_expressions: Possible SQL injection vector through string-based query construction.

Test ID: B608

Severity: MEDIUM

Confidence: LOW

CWE: [CWE-89](#)

File: [./app/routes/auth.py](#)

Line number: 60

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html

```
59     query = (  
60         "SELECT * FROM users WHERE username = '"  
61         + creds.username  
62         + "' AND password = '"
```

hardcoded_password_default: Possible hardcoded password: 'admin'

Test ID: B107

Severity: LOW

Confidence: MEDIUM

CWE: [CWE-259](#)

File: [./app/routes/auth.py](#)

Line number: 87

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b107_hardcoded_password_default.html

```
86     @router.post("/admin-login")  
87     def admin_login(password: str = "admin"):  
88         # BANDIT B106: Hardcoded password function argument  
89         sqlite3_dummy_connect(password="root123")  
90         return {"status": "ok"}  
91
```

hardcoded_password_funcarg: Possible hardcoded password: 'root123'

Test ID: B106

Severity: LOW

Confidence: MEDIUM

CWE: [CWE-259](#)

File: [./app/routes/auth.py](#)

Line number: 89

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b106_hardcoded_password_funcarg.html

```
88         # BANDIT B106: Hardcoded password function argument  
89         sqlite3_dummy_connect(password="root123")  
90         return {"status": "ok"}
```

blacklist: Consider possible security implications associated with pickle module.

Test ID: B403

Severity: LOW

Confidence: HIGH

CWE: [CWE-502](#)

File: [./app/routes/files.py](#)

Line number: 7

More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b403-import-pickle

```
6     import shutil  
7     import pickle  
8     import marshal
```

blacklist: Consider possible security implications associated with the subprocess module.

Test ID: B404

Severity: LOW

Confidence: HIGH

CWE: [CWE-78](#)

File: [./app/routes/files.py](#)

Line number: 9

More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b404-import-subprocess

```
8     import marshal  
9     import subprocess  
10    import xml.etree.ElementTree as ET
```

blacklist: Using xml.etree.ElementTree to parse untrusted XML data is known to be vulnerable to XML attacks. Replace xml.etree.ElementTree with the equivalent defusedxml package, or make sure defusedxml.defuse_stdlib() is called.

Test ID: B405

Severity: LOW

Confidence: HIGH

CWE: [CWE-20](#)

File: [./app/routes/files.py](#)

Line number: 10

More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b405-import-xml-etree

```
9     import subprocess  
10    import xml.etree.ElementTree as ET  
11
```

start_process_with_a_shell: Starting a process with a shell, possible injection detected, security issue.
Test ID: B605
Severity: HIGH
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 44
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html

```
43         # Exposing the filename to shell trivially enables RCE.  
44         os.system("ls -l" + file.filename)  
45
```

subprocess_popen_with_shell_equals_true: subprocess call with shell=True identified, security issue.
Test ID: B602
Severity: HIGH
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 47
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html

```
46         # BANDIT B602: Subprocess call with shell=True  
47         subprocess.call("ls " + file.filename, shell=True)  
48
```

start_process_with_partial_path: Starting a process with a partial executable path
Test ID: B607
Severity: LOW
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 50
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html

```
49         # BANDIT B603: Subprocess without shell but unsafe input  
50         subprocess.call(["ls", file.filename])  
51
```

subprocess_without_shell_equals_true: subprocess call - check for execution of untrusted input.
Test ID: B603
Severity: LOW
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 50
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html

```
49         # BANDIT B603: Subprocess without shell but unsafe input  
50         subprocess.call(["ls", file.filename])  
51
```

subprocess_popen_with_shell_equals_true: subprocess call with shell=True identified, security issue.
Test ID: B602
Severity: HIGH
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 53
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b602_subprocess_popen_with_shell_equals_true.html

```
52         # BANDIT B604: Any other subprocess with shell=True  
53         subprocess.Popen(file.filename, shell=True)  
54
```

start_process_with_partial_path: Starting a process with a partial executable path
Test ID: B607
Severity: LOW
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 56
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b607_start_process_with_partial_path.html

```
55         # BANDIT B607: Starting process with partial path  
56         subprocess.call("ls")  
57
```

subprocess_without_shell_equals_true: subprocess call - check for execution of untrusted input.
Test ID: B603
Severity: LOW
Confidence: HIGH
CWE: [CWE-78](#)
File: [./app/routes/files.py](#)
Line number: 56
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b603_subprocess_without_shell_equals_true.html

```
55         # BANDIT B607: Starting process with partial path
56         subprocess.call("ls")
57
```

blacklist: Pickle and modules that wrap it can be unsafe when used to deserialize untrusted data, possible security issue.
Test ID: B301
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-502](#)
File: [./app/routes/files.py](#)
Line number: 65
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b301-pickle

```
64         data = await file.read()
65         obj = pickle.loads(data)
66
```

blacklist: Deserialization with the marshal module is possibly dangerous.
Test ID: B302
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-502](#)
File: [./app/routes/files.py](#)
Line number: 68
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b302-marshal

```
67         # BANDIT B302: Marshal usage
68         marshaled = marshal.loads(data)
69         return {"msg": "Deserialized successfully"}
```

hardcoded_tmp_directory: Probable insecure usage of temp file/directory.
Test ID: B108
Severity: MEDIUM
Confidence: MEDIUM
CWE: [CWE-377](#)
File: [./app/routes/files.py](#)
Line number: 76
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108_hardcoded_tmp_directory.html

```
75         # BANDIT B108: Hardcoded temp file path
76         with open("/tmp/file.xml", "wb") as f:
77             f.write(data)
```

blacklist: Using xml.etree.ElementTree.parse to parse untrusted XML data is known to be vulnerable to XML attacks. Replace xml.etree.ElementTree.parse with its defusedxml equivalent function or make sure defusedxml.defuse_stdlib() is called
Test ID: B314
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-20](#)
File: [./app/routes/files.py](#)
Line number: 79
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b313-b320-xml-bad-elementtree

```
78
79         tree = ET.parse("/tmp/file.xml")
80         return {"root": tree.getroot().tag}
```

hardcoded_tmp_directory: Probable insecure usage of temp file/directory.
Test ID: B108
Severity: MEDIUM
Confidence: MEDIUM
CWE: [CWE-377](#)
File: [./app/routes/files.py](#)
Line number: 79
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b108_hardcoded_tmp_directory.html

```
78
79         tree = ET.parse("/tmp/file.xml")
80         return {"root": tree.getroot().tag}
```

blacklist: Use of possibly insecure function - consider using safer ast.literal_eval.
Test ID: B307
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-78](#)
File: [/app/routes/profile.py](#)
Line number: 63
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval

```
62         try:
63             eval(payload.username)
64         except:
```

try_except_pass: Try, Except, Pass detected.
Test ID: B110
Severity: LOW
Confidence: HIGH
CWE: [CWE-703](#)
File: [/app/routes/profile.py](#)
Line number: 64
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html

```
63             eval(payload.username)
64         except:
65             pass
66
```

django_mark_safe: Potential XSS on mark_safe function.
Test ID: B703
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-80](#)
File: [/app/routes/profile.py](#)
Line number: 81
More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b703_django_mark_safe.html

```
80     # BANDIT B308: Use of mark_safe (Django XSS risk)
81     safe_str = mark_safe(html)
82     return HTMLResponse(safe_str)
```

blacklist: Use of mark_safe() may expose cross-site scripting vulnerabilities and should be reviewed.
Test ID: B308
Severity: MEDIUM
Confidence: HIGH
CWE: [CWE-79](#)
File: [/app/routes/profile.py](#)
Line number: 81
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b308-mark-safe

```
80     # BANDIT B308: Use of mark_safe (Django XSS risk)
81     safe_str = mark_safe(html)
82     return HTMLResponse(safe_str)
```

blacklist: The pyCrypto library and its module ARC4 are no longer actively maintained and have been deprecated. Consider using pyca/cryptography library.
Test ID: B413
Severity: HIGH
Confidence: HIGH
CWE: [CWE-327](#)
File: [/app/utils.py](#)
Line number: 7
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_imports.html#b413-import-pycrypto

```
6     from datetime import datetime
7     from Crypto.Cipher import ARC4, AES
8
```

blacklist: Use of insecure cipher Crypto.Cipher.ARC4.new. Replace with a known secure cipher such as AES.
Test ID: B304
Severity: HIGH
Confidence: HIGH
CWE: [CWE-327](#)
File: [/app/utils.py](#)
Line number: 24
More info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b304-b305-ciphers-and-modes

```
23     # BANDIT B304: Use of insecure cipher
24     cipher1 = ARC4.new(b"key")
25     encrypted1 = cipher1.encrypt(data)
```

request_without_timeout: Call to requests without timeout

Test ID: B113

Severity: MEDIUM

Confidence: LOW

CWE: [CWE-400](#)

File: [./app/urls.py](#)

Line number: 33

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b113_request_without_timeout.html

```
32         # BANDIT B113: Requests without timeout
33         response = requests.get(url)
34         return response.text
```

try_except_continue: Try, Except, Continue detected.

Test ID: B112

Severity: LOW

Confidence: HIGH

CWE: [CWE-703](#)

File: [./app/urls.py](#)

Line number: 41

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b112_try_except_continue.html

```
40         print(msg)
41         except Exception:
42             continue
```

flask_debug_true: A Flask app appears to be run with debug=True, which exposes the Werkzeug debugger and allows the execution of arbitrary code.

Test ID: B201

Severity: HIGH

Confidence: MEDIUM

CWE: [CWE-94](#)

File: [./main.py](#)

Line number: 41

More info: https://bandit.readthedocs.io/en/1.9.4/plugins/b201_flask_debug_true.html

```
40         flask_app = Flask(__name__)
41         flask_app.run(debug=True)
42
```